

Autenticação em SSH (Secure Shell)

Com este trabalho pretende-se estudar a configuração e exploração de sessões seguras com SSH (Secure SHell). Elabore um relatório que detalhe aspetos relevantes do seu trabalho e que responda às questões de desafios que são lançados ao longo do guião. Ilustre as suas respostas com capturas de ecrã que mostrem os aspetos a que elas se referem.

Neste trabalho deverá usar duas máquinas virtuais Linux, que pode reutilizar das aulas anteriores. Uma das máquinas (Máquina M1) será usada como servidor SSH e a outra máquina será usada como cliente SSH.

Não se esqueça de que a prompt das máquinas deve incluir o seu número mecanográfico, com por exemplo: nnn-servidor e nnn-cliente, em que nnn é o seu número mecanográfico.

Faça um relatório detalhando as várias etapas do trabalho, incluindo capturas de ecrã como evidências da realização do trabalho, e com respostas às eventuais perguntas que surjam no guião. No final, submeta o relatório na pasta da disciplina na plataforma de elearning.

1 Configuração

Nesta secção vamos configurar as duas máquinas, servidor (M1) e cliente (M2), e a rede para elas comunicarem.

Comece por configurar o adaptador de rede de ambas as máquinas virtual para usar a rede NAT (NAT Network) que criou em aula anterior.

1.1 Máquina Servidor (M1)

Verifique se o serviço SSH está ativo na máquina servidor (M1). Para isso, verifique se o respetivo porto TCP (porto 22) está disponível para receber ligações, utilizando o seguinte comando:

```
$ netstat -atn
```

Os seguintes passos permitem a instalação e configuração inicial de um servidor SSH numa máquina Linux. Use os que forem adequados para instalar os serviços em falta na máquina M1.

Instale um servidor de SSH utilizando o seguinte comando:

```
$ sudo apt-get install openssh-server
```

Usando o comando `netstat` acima, verifique se o servidor de SSH está ativo (serviço à escuta no porto 22). Caso seja necessário reiniciar o servidor de SSH, faça-o utilizando o seguinte comando:

```
$ sudo service ssh restart
```

Garanta também que tem o analisador de protocolos Wireshark instalado. Caso seja necessário, pode instalá-lo usando o comando

```
$ sudo apt-get install wireshark
```

1.2 Máquina Cliente (M2)

Verifique se nesta máquina tem instalados o Wireshark e a aplicação cliente de ssh (comando `ssh`, na linha de comandos). Caso não tenha, usando o comando `apt-get`, instale-as usando os respetivos comandos:

```
$ sudo apt-get install wireshark
```

```
$ sudo apt-get install ssh
```

2 Inspeção do tráfego de rede

Verifique a conectividade entre as suas duas máquinas e garanta que elas comunicam entre si.

Na máquina cliente, configure o Wireshark para mostrar apenas tráfego SSH e inicie uma captura de tráfego .

Inicie agora uma sessão SSH para a máquina servidora, usando o seguinte comando, usando o seu username no servidor e o endereço IP do seu servidor SSH:

```
$ ssh <username>@<endereço servidor>
```

Caso seja a sua primeira ligação SSH ao servidor, o servidor irá identificar-se através da sua chave pública e aparecerá uma janela a perguntar se pretende guardar essa chave; responda afirmativamente. Faça login e liste o conteúdo da pasta raiz com o comando:

```
$ ls /
```

Termine a sessão SSH e termine a captura no Wireshark.

Analise os pacotes SSH capturados pelo Wireshark e indique o que conclui quanto à segurança do protocolo SSH, comparativamente com o tráfego Telnet que observou numa aula anterior.

3 Autenticação em SSH

Nesta secção iremos analisar a forma como o servidor e os clientes se autenticam no protocolo SSH. Assume-se que os ficheiros de configuração do SSH estão na sua versão original, i.e., ainda não sofreram nenhuma alteração.

3.1 Autenticação do servidor

Na primeira interação de um cliente com um servidor SSH, o cliente tem de validar a identidade do servidor. Para esse efeito, o servidor SSH envia ao cliente a sua chave pública, e o respetivo *fingerprint* é apresentado ao utilizador para que este possa confirmar se é ou não o *fingerprint* da chave pública do servidor a que pretende aceder.

De facto o servidor SSH cria não um par de chaves, mas sim três: um para o algoritmo RSA, outro para o algoritmo DSA e outro para o algoritmo com Curvas Elípticas. Quando o cliente aceder ao servidor ser-lhe-à mostrado o *fingerprint* da chave pública de um destes três pares de chaves. Estes *fingerprint* devem ser dados ao utilizador quando a sua conta é criada, ou quando lhe é dado acesso através de SSH. Para obter estes fingerprints, na máquina servidora (M1) execute os seguintes comandos e tome nota dos valores dos *fingerprints*:

```
$ sudo ssh-keygen -lf /etc/ssh/sssh_host_rsa_key.pub
$ sudo ssh-keygen -lf /etc/ssh/ssh_host_ecdsa_key.pub
$ sudo ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
```

Na máquina cliente (M2) elimine eventuais chaves públicas que estejam armazenadas em resultado de interações anteriores com servidores SSH. Para isso, use o seguinte comando:

```
$ rm ~/.ssh/known_hosts
```

A partir da máquina cliente (M2) aceda ao servidor SSH, usando o seguinte comando, onde *username* é o seu nome de utilizador no servidor e *host* é o nome da máquina servidor ou o seu endereço IP:

```
$ ssh username@host
```

O utilizador verá uma mensagem semelhante à apresentada abaixo, a perguntar se confia ou não na identidade do servidor de SSH que está a contactar.

```
$ ssh username@host
The authenticity of host '10.0.0.1 (10.0.0.1)' can't be established.
RSA key fingerprint is 6a:de:e0:af:56:f8:0c:04:11:5b:ef:4d:49:ad:09:23.
Are you sure you want to continue connecting (yes/no)? no
```

Compare o *fingerprint* apresentado pelo servidor, tenha em atenção qual o algoritmo do fingerprint (no caso acima é RSA), com o *fingerprint* do mesmo algoritmo que antes obteve no servidor. Se forem iguais, é porque está a interagir com o servidor correto e deve responder **yes**. Se não, deve terminar a sessão, respondendo **no**.

Depois de confirmar, o cliente irá armazenar a chave pública no ficheiro `~/.ssh/known_hosts` e não voltará a questionar o utilizador, a menos que o servidor apresente uma chave pública diferente.

Na sua configuração original, os clientes autenticam-se perante o servidor usando a *password* da sua conta no servidor. Introduza a sua password para terminar o processo de autenticação e iniciar a sua sessão SSH.

Como foi referido, o fingerprint da chave pública do servidor foi fornecido ao utilizador quando a sua conta foi criada, para este depois o usar para autenticar o servidor. Acha que esta forma de distribuir chaves públicas para a autenticação do servidor SSH poderia ser usada para a autenticação dos servidores Web na Internet, por exemplo para garantir que está a aceder ao servidor da Google ou do Facebook? Justifique a sua resposta.

3.2 Autenticação do cliente com chaves assimétricas

NO SSH, o utilizador também pode autenticar-se perante o servidor através de um par de chaves. Para criar um par de chaves RSA para o cliente, na máquina cliente use o seguinte comando:

```
$ ssh-keygen -t rsa
```

Prima Enter para aceitar o nome por omissão (**não altere este nome**) para o ficheiro onde vai ser guardado o par de chaves e introduza uma password de proteção.

Depois de criado o par de chaves do utilizador, é necessário fornecer a respetiva chave pública ao servidor de SSH para que este a possa associar ao utilizador e depois a possa usar no processo de autenticação do utilizador. Para fornecer a

chave pública do utilizador ao servidor, na máquina cliente, use o seguinte comando:

```
$ ssh-copy-id -i ~/.ssh/id_rsa.pub <username>@<server>
```

no qual `~/.ssh/id_rsa.pub` é o nome do ficheiro que contém a chave pública do par de chaves que acima criou, **username** é o nome do utilizador no servidor a quem a chave pertence e **server** é o nome do servidor SSH onde se pretende instalar a chave pública. Este comando coloca o ficheiro com a chave pública do utilizador no ficheiro `~/.ssh/authorizedkeys` localizado na pasta pessoal do utilizador no servidor de SSH. Esta chave será usada na autenticação do cliente para validar se este possui a correspondente chave privada.

Para que o servidor SSH não permita autenticação através de passwords, na **máquina Servidor**, aceda ao ficheiro `/etc/ssh/sshd_config` e garanta que a variável `PasswordAuthentication` não está em comentários e que fica com o valor **no**.

```
PasswordAuthentication no
```

Depois da alteração, reinicie o serviço SSH usando o seguinte comando:

```
$ sudo service ssh restart
```

Para testar o acesso do utilizador, na sua **máquina cliente**, repita o início de sessão SSH para a máquina servidora.

```
$ ssh username@host
```

Teve de introduzir a sua *password* para fazer *login*?

E se tentar aceder ao servidor a partir de uma outra máquina cliente? O que irá acontecer em relação à sua autenticação?

Analise as vantagens e desvantagens da autenticação por chaves assimétricas em relação à autenticação por senha partilhada (senha).

3.3 Autenticação com dois fatores

O SSH permite autenticação usando dois fatores de autenticação: a chave pública e uma senha descartável recebida no seu telemóvel. Para isso tem de usar a aplicação Google Authenticator no seu telemóvel.

Faça uma procura por “SSH Two Factor Authentication” e configure o seu servidor SSH para usar autenticação com dois fatores.

Descreva no relatório os passos que deu para fazer a instalação.

Quais as vantagens e desvantagens deste modo de autenticação em relação à autenticação através de password?

4 Conclusão

Quando terminar o seu relatório, submeta-o na plataforma de elearning.